

6/29 – Introduction to Support, Systems Overview & AI in Support

Introduction to Support and Beyond

Speaker: Jen, Director of Support

Core Customer Service Attributes

- Customer service success comes down to a consistent set of attributes regardless of industry or product
- **Speed** – customers want resolution to happen quickly; delays are one of the most common frustrations regardless of outcome
- **Pleasant attitude** – tone matters as much as outcome; even a difficult resolution feels better when delivered with warmth
- **Communication** – customers want to know what is happening; silence or unexplained actions (eg a bank card suddenly stopped working without notice) erode trust fast
- **Active listening** – the most critical skill in technical support; customers often cannot articulate their problem precisely, so the analyst must ask questions and pull the information out; analogized to a customer at a smoothie shop saying only "I want a smoothie" – you have to probe for what they actually need
- **Empathy** – acknowledging the customer's frustration diffuses tension even before the problem is solved; simply saying "I understand this is frustrating" goes a long way
- **Ownership and accountability** – if support made an error, own it; apologize and be genuinely part of the solution
- **Adaptability** – different customers have different personalities and thresholds; what feels like great service to one person may feel mediocre to another; meeting the customer where they are is essential
- **Multitasking** – unlike a coffee shop transaction that is opened and closed in one interaction, support cases at Evisions often span many sessions and interactions; analysts commonly manage 40–50 open cases simultaneously and must triage and cadence their work accordingly
- **Lifelong curiosity** – the best support analysts are always looking to learn more; if you dislike learning new things, support is not the right fit

Handling Difficult Situations

- **Angry customers** – remain calm; never match the customer's energy; acknowledge their frustration with empathy first before moving toward resolution
- **Delivering bad news** – some problems cannot be solved immediately; engineering may need to write new code, which could take days, weeks, or months; be honest about this, do not make promises you cannot keep, and commit to providing updates on a cadence so the customer never feels forgotten
- **Workarounds** – when a direct fix is not available, look for partial solutions that can keep the customer moving; example: a president needing a dashboard for a donor meeting where the report is broken – can data be extracted another way to get them something useful?
- **Escalations** – know when to pull in a colleague, a technical specialist, or engineering; escalating appropriately and early is better than letting a customer stew; do not let a customer's frustration escalate internally at their institution before you have a handle on the situation
- **Gauging customer temperature** – proactively read whether a customer is nearing a boiling point; a case that seemed routine can blow up if the customer's internal frustration was never communicated back to support, leading to a blindsiding escalation

Adaptability and Support vs Professional Services

- There is a clear line between what support covers (answering questions, guiding users through existing functionality, troubleshooting) and what Professional Services covers (building things for the client, which is billable)
- Support analysts must stay aware of when a conversation is sliding from support into development work; customers will naturally push for more help than they are entitled to – not out of malice, but because they simply want their problem solved
- Example: helping a client understand how to build a report is support; building the report for them is professional services
- Being too nice in support can undercut revenue; maintaining the boundary protects both the client relationship and the business model

Support Team Structure at Evisions

- Four analyst levels: Trainee, Level 1, Level 2, Level 3; level determines number of products covered, experience requirements, and additional responsibilities
- **Technical Support Specialist** – above the analyst levels; handles fewer direct cases; serves as an escalation resource for analysts; knows all products at a deeper technical level including multi-factor authentication, operating systems, servers, and clustering
- **Support Manager** – ensures operational smoothness daily; manages queue health, inter-departmental coordination, CSAT scores, and analyst growth paths
- Support org design is flexible – there is no single right answer; orgs can have two levels or ten, use AI bots for first-line triage, or rely entirely on people

How Support Cases Come In

- Approximately 97–98% of cases come in through the customer community portal (web form submission)
- Approximately 2–2.5% come in via email to support@evisions.com, typically from users without portal access
- Approximately 0.5% or less come in by phone; callers are usually following up on an already-submitted urgent case trying to reach someone live faster
- Zoom is the tool used for live troubleshooting – letting the customer share their screen and show exactly what is happening is far more efficient than trying to describe it in text

AI in Support – Current State and Future Consideration

- Evisions does not currently use AI as a first-line support bot, but it is used as a productivity tool by analysts (covered in the AI session below)
- When designing a support organization, AI can be considered as: a first-response bot for simple questions, a tool that searches the knowledge base and suggests articles before a case is even submitted, or a combination with human analysts for complex issues
- Customers surveyed in the session expressed skepticism about AI phone bots and chat bots; most prefer to reach a live person quickly; the threshold for AI acceptance was somewhat higher for web-based chat vs phone
- The goal is to push as much as possible toward self-service and deflection (customers finding their own answers) to reduce cost-per-interaction

Systems Overview

Speaker: Jen, Director of Support

Salesforce as the CRM

- Salesforce is the primary CRM at Evisions; approximately 50–60% of the company holds a Salesforce license; used across support, sales, marketing, professional services, and client engagement
- Salesforce owns Slack; the company’s stated vision is that eventually users will not need to log into Salesforce directly – all interactions will flow through Slack integration and AI agents
- **Support Case Dashboard** – Jen uses a management dashboard in Salesforce to monitor key support metrics at a glance: open case count, case aging, customer satisfaction trends; analysts have their own dashboards showing their personal queue health and performance vs peers

Case Queues and Triage

- Cases are organized into queues – a general queue for all incoming cases and product-specific queues (eg an Argos-only queue)
- Evisions uses a **self-select model** – analysts choose which cases to pick up based on their workload and expertise; cases are not auto-assigned or round-robin (though those are valid options)
- Each case contains: product and version, customer contact information, description of the issue, attached files (error screenshots, diagnostic logs), prior case history, and customer-specific notes
- Analysts can post internal notes (invisible to the customer) for collaboration, as well as customer-facing email communications, all within the case record
- **JIRA integration** – when a case reveals a product defect or enhancement need, a JIRA ticket is created for engineering; the JIRA must document exact steps to reproduce the issue so QA can validate the fix; Evisions does not backport fixes to older product versions
- Time tracking is required per case so Evisions can understand where analyst hours are spent and meet tax credit documentation requirements

Prioritization and SLAs

- Triage is analogized to an emergency room – not everything submitted as urgent truly is, and analysts must apply judgment
- **True urgent/emergency** – system is completely down; nothing works; all users affected
- **Also urgent at Evisions** – check printing failures (FormFusion/IntelliCheck), since payroll checks cannot be delayed; people need to get paid
- **Not urgent despite customer perception** – a single report not running; an individual user locked out; issues in a test environment (non-production issues cannot be urgent by policy)
- SLAs define response time targets by priority level; support tracks adherence to SLAs as a key operational metric

Customer Community Portal

- The customer community is a gated portal (login required) through which clients submit cases, view their case history, browse knowledge articles, and interact with other institutions
- **Case submission** – before a customer can even type in their issue description, the portal surfaces relevant knowledge articles in real time based on what they type; this **deflection** mechanism aims to push customers toward self-service; Evisions does not currently have reliable reporting on how often deflection actually succeeds
- **Customer-facing case view** – shows correspondence and file attachments but hides internal analyst notes; customers can see case status and a message to open a new case rather than

reopen closed ones

- **Community discussions** – institutions can communicate with each other through the portal; higher ed clients are notably collaborative and freely share knowledge and solutions with peer institutions
- **CO-OP** – customers can publish data blocks they have built to a shared library for other institutions to download and adapt; Evisions also publishes starter packs of pre-built data blocks through this channel
- **Knowledge base** – approximately 2,800 articles maintained across all products; articles are categorized and searchable; knowledge articles are created by support analysts and reviewed for consistent voice; the portal has not been significantly redesigned in seven years and is a candidate for a UX refresh

VPAT and Accessibility

- **VPAT (Voluntary Product Accessibility Template)** – a document that discloses how a software product meets federal accessibility standards (Section 508); required in higher ed where institutions must ensure tools are accessible to users with visual, hearing, and other disabilities
- Evisions maintains VPAT knowledge articles for each product documenting areas of compliance and non-compliance

AI Session – How AI Tools Are Leveraged in Support

Speakers: Jewel and Ditas, Technical Support Specialists

The Problem AI Solves

- Support knowledge at Evisions is scattered across many disconnected systems: Slack threads, Zoom recording transcripts, internal analyst notes, JIRA tickets, Confluence pages, Salesforce case history, and web help documentation
- The answer to a new problem is often buried three threads deep in a Slack conversation from eight months ago – not searchable, not surfaced, not visible to the analyst who needs it
- AI tools help pull scattered context from these different systems into something usable, fast – collapsing 30–60 minutes of research and content creation into 5–15 minutes

AI Tools Used

- **Slack AI** – built into Slack; free with the Slack subscription; used to summarize lengthy Slack threads and draft knowledge article or client email content from those threads; learning/training mode is turned off per IT requirement
- **Claude (Anthropic)** – paid version used by technical specialists; used for document analysis, JIRA drafting, code problem-solving, and synthesizing siloed information into structured outputs; learning/training mode off per IT requirement
- Every AI tool used at Evisions goes through an IT approval process covering: data security (training off), legal and contractual protections for confidentiality, compliance with data privacy laws and SOC 2, and vendor vetting for history and certifications
- Sensitive data – especially PII – is never pasted into any AI tool; all client-identifying information is removed before any content goes into an AI system

Use Case 1 – Knowledge Article from Slack Thread

- A Slack thread in which support analysts worked through a scheduling behavior question was turned into a knowledge article using Slack AI
- Workflow: paste the Slack thread link into Slack AI → prompt: "Please draft a knowledge

article based on the contents of this thread” → AI outputs a structured draft covering the issue, explanation, and resolution

- The same thread can also be prompted to produce a client-facing email explanation with a single follow-up prompt
- Output quality is reviewed and lightly edited before publishing; the analyst’s job shifts from building content from scratch to reviewing and refining AI-generated drafts

Use Case 2 – JIRA from Siloed Information

- Engineering has specific requirements for JIRA submissions (steps to reproduce, versions tested, version the bug appeared in, etc); submissions missing required fields are returned to support without being reviewed
- Workflow: upload the JIRA creation guide (a Word document from engineering) as context → provide the issue summary → prompt Claude to produce a JIRA draft meeting all specification requirements
- Claude produces a well-structured draft and proactively flags missing fields (eg ”don’t forget to include the version number”)
- The reverse workflow also works: paste a draft JIRA into Claude along with the creation guide and ask it to identify gaps before submission

Use Case 3 – FormFusion Shell File Fix (Long-Running Bug)

- **Background** – FormFusion takes raw Banner data and formats it into clean documents (tax forms, purchase orders, invoices); in 2022 the 1099 NEC process changed from a Proceed-type (FormFusion-compatible) to a Java process (FormFusion-incompatible), breaking a heavily used tax template
- A shell file workaround was implemented to reroute output through Evisions’ print command instead of Banner’s default, which fixed most clients but not all
- The remaining failures showed a username being prepended to the expected file name in the log; the job looked for the file without the username, could not find it, and threw an empty error – the root cause was identified but no one on the team had the code experience to write the fix
- **Claude’s solution** – after uploading all installation guides, documentation, and the shell file into a Claude project with full context: Claude proposed copying the file with the username prepended (the file the print step was actually looking for), running the print job, then deleting the copy; three lines of code that solved a three-year-old problem
- Fix was tested on a real client case (with client permission) before being declared a valid solution

Use Case 4 – IntelliCheck Invoice Number Wrapping

- **Background** – IntelliCheck handles check printing; Ellucian extended invoice numbers to 35 characters but the check stub only had room for 27; the prior workaround was to truncate at 27 characters, which clients tolerated until a client specifically needed all 35 to appear
- The requirement: show all 35 characters with the overflow wrapping to the next line, while keeping the date and description on the same line and not breaking any other formatting
- Every fix attempted independently broke other elements of the check stub layout
- **Claude’s approach** – uploaded implementation guides, the baseline check stub code, and a precise description of the problem and requirement; Claude proposed a conditional length-check block: if the invoice number exceeds 27 characters, route to a wrapping subroutine; if between 16 and 27, print normally on its own line; if 15 or fewer, print as-is with everything else

- Tested first in the internal test environment, then with a long invoice number, then with a long invoice number *and* a long description simultaneously to ensure no downstream breakage; all scenarios held up

The Catch – Where AI Falls Short

- **Hallucinations** – AI can produce a confident, well-structured answer that is completely wrong; the analyst must have enough knowledge of the subject to recognize when this is happening; asking AI to cite or explain where it got information often exposes fabricated reasoning
- **Scope blindness** – AI answers exactly the question asked; if the question is too narrow, it may solve one scenario at the expense of breaking another; always ask: is this going to break anything else? Are there other scenarios this needs to handle?
- **Real-world testing required** – proposed AI solutions are hypotheses, not confirmed fixes; every solution must be tested in a controlled environment before being applied to a real client case, and ideally against multiple edge case scenarios
- **Ownership stays with the analyst** – if AI gives a wrong answer and you publish it, you are wrong, not the AI; the analyst’s name is on the output; responsibility does not transfer to the tool
- **PII discipline** – never share client-identifying data, student records, or sensitive institutional information with any AI tool, approved or otherwise

Best Practices for AI in a Support Role

- **Mind security** – ensure learning/training mode is off; be deliberate about what data goes in; follow the IT-approved tool list
- **Give the prompt everything** – context quality determines output quality; set the stage with background, explain the system involved, describe the specific problem, provide relevant files and documentation; vague prompts yield vague answers
- **Prompt engineering** – asking AI to assume a role (eg ”You are a technical writer with five years of experience in enterprise software documentation”) or to follow specific instructions layers additional quality into the output
- **Use projects and containers** – Claude projects maintain conversation history and source documents across sessions; prevents losing context and ensures consistent reference material
- **Validate the content** – treat every AI output as a draft; review for accuracy, test any proposed code or solutions, and have subject-matter experts review AI-assisted content before it goes out
- **Expect hallucinations and plan for them** – ask AI to explain its reasoning; cross-check surprising claims; test AI against AI if needed (different tools may give different answers, which itself is informative)
- **Use it to learn, not just to produce** – asking AI to explain its logic builds the analyst’s own knowledge rather than creating dependence; the goal is augmentation, not replacement

Operations & Technical Documentation Q&A

Speakers: Brent (Technical Writer) and Shelley (Operations/Salesforce Administrator)

Technical Documentation – Brent

- Brent is Evisions’ sole technical writer; English degree, not a technical background; works closely with developers, QA, and support to ensure accuracy and appropriate tone for both technical and non-technical audiences
- **Primary outputs:**

- Online web help (updated for every major Maps release)
- Release guides (length varies based on release scope)
- Task-specific guides (eg hardware/software specs, step-by-step task documentation)
- Beta guides for direct beta testing programs
- Editing support for documentation owned by others (Accelerator docs, data block starter pack documentation from Matt Schick)
- **Tool: MadCap Flare** – the primary technical writing tool; template-based, supports multi-output publishing (web help, PDF, etc); integrates with a global project containing a version matrix referenced heavily by support; documentation not in Flare is produced as Word documents converted to PDF
- **Readability standard** – all documentation targets a Flesch-Kincaid readability score of approximately 8th to 9th grade; keeps docs accessible to both technical power users and casual report viewers; passive voice is the preferred register for release notes
- **AI in technical writing** – used primarily for consistency checks (is this in correct passive voice? what is the readability score?) and for decomposing complex multi-part JIRA tickets into plain-language summaries; also uses the built-in AI in JIRA/Novo to step-by-step break down dense engineering tickets; has not replaced the writing itself; hallucinations are occasional but manageable given Brent’s close review process
- **Skills for tech writers alongside AI** – strong grasp of English, knowledge of the industry’s terminology and standards, and most critically the ability to write effective prompts; the more specific and layered the prompt, the better the AI output; AI needs human expertise to prompt it correctly
- **Success measurement** – release guides shipped on schedule; readability score targets met; team satisfaction with published documentation; no significant customer-facing documentation errors

Operations – Shelley

- Shelley is one of Evisions’ longest-tenured employees; degree in finance, started in consulting for report writing and data work, met the founder Kevin Jones, and has been at Evisions since near the beginning
- Role is cross-functional and defies a single description: primarily Salesforce administration and automation, data imports, integrations, and special projects; the catch-all for anything that does not have a clear owner
- Previously ran support; her view is that the core philosophy of customer care at Evisions has not changed despite technology improvements – the level of service has remained consistently high
- **Salesforce administration** – Salesforce has been in use since 2019; it is a large and constantly evolving system; Shelley helps departments ask better questions of their data, builds reports and dashboards, and removes friction from processes (if you are clicking five times to do something, tell her – it can probably be automated)
- Encourages all team members to always question why they are doing something manually and raise it; efficiency improvements benefit the whole organization
- **AI use in operations** – primarily for Salesforce-related research; AI helps Shelley discover features and approaches she might not have found through traditional search, think through problems differently, and stay ahead of a platform that is constantly adding new capabilities; AI is not always right and sometimes requires correction, but it expands what is possible to try
- The customer community portal (seven years old, due for a redesign) is a known area where

user experience could be improved; the search is functional but not highly precise, and the visual design is dated; no formal redesign has been resourced yet

- **Evisions support hours** – 8 AM Eastern to 8 PM Eastern (5 AM to 5 PM Pacific), Monday through Friday; covered by two shifts of analysts; not a 24/7 support organization; cases can be submitted anytime and will be addressed when the shift begins
- **Success measurement for operations** – there is no direct CSAT for Shelley’s work; success is measured by whether internal stakeholders have the data and tooling they need, processes run smoothly, and the overall system functions without escalation; support’s CSAT is tracked separately (average 4.95/5.0 based on approximately 60 survey responses per month out of roughly 450 cases)

ewpage

6/30 – Support Operations, Support Team Q&A & Troubleshooting

Support Operations – KPIs, SLAs, Scheduling, Pricing & Licensing

Speaker: Jen, Director of Support

KPIs – Measuring Support Performance

- **KPI (Key Performance Indicator)** – measurable signals used to assess whether a support organization is performing as expected; without KPIs, there is no way to know if the team is doing the right work in the right way
- **Metrics Jen tracks in Salesforce dashboards:**
 - **Case count by analyst** – how many open cases each analyst currently owns; higher-tier analysts typically carry fewer cases because theirs are more complex
 - **Case aging** – how long each case has been open; cases open over 30 days are flagged and shared with the client engagement team as a potential relationship risk
 - **CSAT (customer satisfaction surveys)** – optional survey sent after each case closes; scores on a 1–5 scale; Evisions averages 4.95/5.0 consistently; filters who responds (typically very satisfied or very dissatisfied customers, not neutral ones)
 - **Product satisfaction** – separate from service quality; asks whether the product itself is meeting the client’s needs; a team can deliver great service on a product clients dislike, which creates renewal risk
 - **SLA adherence** – what percentage of cases were responded to within the contractually defined window; Evisions targets 98%+ and consistently meets it; misses are reviewed to understand root cause (inundation, expertise gap, after-hours timing)
 - **Case volume by time of day** – tracks when cases arrive relative to business hours; informs future decisions about whether to extend shift coverage toward 24/7
 - **Open cases by status** – snapshot of how many cases are waiting on the customer, waiting on engineering, actively in progress, etc
 - **Time spent per case by product** – analysts log time on every case; aggregated data helps engineering make prioritization decisions and supports tax credit documentation
 - **Cases opened and closed per month by product** – tracks volume trends and identifies which products generate the most support load
 - **Cases per analyst per week** – workload distribution view; surfaces any analyst who may be overburdened or underutilized
- The dashboard gives a snapshot that can be clicked into for detail; reviewing aggregate KPIs daily instead of individual case detail allows Jen to manage at the right altitude without

spending all her time in the weeds

SLA – Service Level Agreement

- **SLA (Service Level Agreement)** – a formal document that defines what support will and will not do, and the response time commitments for each priority level; included in the software support agreement
- Priority tiers at Evisions: Urgent, High, Medium, Low; customers self-select but Evisions may adjust if the customer’s selected priority does not match the defined criteria
- **What counts as urgent** – system completely down for all users; or a check printing failure (FormFusion/IntelliCheck), since payroll cannot be delayed
- **What does not count as urgent** – a single report not running; issues in a non-production/test environment; individual user problems that do not affect the institution broadly
- SLAs serve a dual purpose: they set customer expectations (so they know when to expect a response) and they define the boundary between support and professional services (anything outside the SLA is either out of scope or billable)
- **Uptime SLAs** – when software is cloud-hosted (SaaS), an additional SLA commits to a minimum uptime percentage (eg 99.9%); Evisions is moving toward this model as clients move away from on-premise software; SaaS hosting changes the operational model and typically requires 24/7 support coverage
- Evisions validates enrollment numbers (used for pricing tiers) against **IPEDS** (Integrated Postsecondary Education Data System) – the federal database where all institutions must report enrollment figures; prevents clients from understating enrollment to reduce their pricing tier

Scheduling

- Evisions support covers 8 AM Eastern to 8 PM Eastern (5 AM to 5 PM Pacific) – a 12-hour window requiring two overlapping shifts; no single analyst works 12 hours
- Support org design must account for: shift coverage, vacation and absence coverage, product expertise distribution across shifts, time carved out for training and professional development (as AI capabilities evolve, analysts need dedicated learning time away from the queue)
- Support functions as a feeder into the broader organization – analysts who learn products deeply become attractive to QA, client engagement, product, and engineering; turnover out of support is often upward mobility, not attrition

Pricing and Licensing

- **Perpetual license** – the customer purchases the software outright and owns it forever; support is an optional add-on fee paid annually; the customer can stop paying for support at any time, ending the recurring revenue relationship; analogous to buying a car outright and paying separately for each service
- **Subscription license** – the customer pays recurring fees (annual or multi-year) that include support; analogous to leasing a car where maintenance is bundled; more predictable recurring revenue; the industry standard for modern software
- **Tiered pricing** – pricing scales with usage or institution size; Evisions tiers by student enrollment count since larger institutions generate more product usage and more support demand; the same software serves a 1,000-student college and a 50,000-student university, but the latter’s demand is substantially higher
- **Consumption model** – charges based on how much the product is actually used (eg number of AI queries, API calls, tokens); used by AI platforms like ChatGPT (free tier caps the number of prompts); companies adopting AI tools without guardrails risk blowing through

budgets quickly

- **Contract term** – multi-year contracts lock in recurring revenue and reduce renewal risk; a client on a 3-year term must pay through the end regardless of whether they continue using the product; single-year terms offer clients more flexibility but expose the vendor to annual churn risk
- **Discounting** – vendors must decide whether to allow price negotiation; institutions often have fixed budgets (“we have \$25,000 to spend”) that require flexibility; the decision to discount is a balance between closing deals and protecting margin
- **Bundling services** – for complex products like Evisions accelerators, clients will almost certainly need implementation help; bundling professional services (implementation, training) with the license reduces friction and ensures the client actually uses the product, driving renewal
- **Enrollment lock-in** – Evisions locks pricing at the current enrollment tier at the time of purchase and does not true-up mid-contract; enrollment in higher ed is broadly declining nationally, so locking in current numbers protects revenue; validated against IPEDS

Get to Know Support – Support Standup Meeting & Q&A with Team

Support team meeting observed live, followed by Q&A

Live Standup – Case in Progress

- The standup meeting is a brief daily or regular collaboration session where analysts share stuck cases and solicit input from the broader team; a core mechanism for avoiding siloed troubleshooting in a remote environment
- **Case observed (Yale – FormFusion PDF issue):**
 - The client is experiencing an access violation error when generating a PDF report through the web viewer; the error occurs when clicking the save button; previewing and printing to a different PDF driver works correctly
 - Stephen (analyst) has been able to reproduce the issue internally with the same data values but cannot reproduce the access violation itself – suggesting the issue is environment-specific (the client’s configuration differs from Evisions’ test environment)
 - The underlying data contains a problematic record; the client’s DBA has been asked to investigate but has pushed back
 - The save action uses eDocEngine to create the PDF; the print-to-PDF workaround uses the printer driver instead – that difference is what causes the divergent behavior
 - Jen flagged a recent precedent where a different client (Alaska) appeared to be in a manageable state but blindsided the team by escalating internally; she urged proactive temperature-checking with Yale and suggested looping in the client engagement/partner team (CET) to have a non-technical relationship check-in
- **Troubleshooting suggestions from the team:**
 - Check printer driver versions and connection settings between the client environment and Evisions’ test environment to find the configuration discrepancy
 - Try a TRIM or two-character function on the problematic record to strip hidden whitespace or special characters
 - Investigate whether the issue is the specific record or the character set (eg non-ASCII characters in the data causing encoding conflicts with eDocEngine)
- **Key lesson** – even when support is doing everything right technically, customers can escalate sideways to executives or other contacts if frustration builds undetected; go on offense rather

than defense by proactively checking in and involving the client relationship team before frustration peaks

Support Team Introductions

- The Evisions support team is notable for long tenure: multiple analysts with 10–20 years at the company; Kirsten (support manager) recently passed her 20-year anniversary; this longevity is cited as a signal of the work environment quality
- **Team backgrounds are diverse** – computer science degrees are common but not universal; the team includes an art degree holder, a math degree holder, and analysts from entirely non-technical backgrounds who transitioned through training and experience
- All analysts are directly client-facing and manage their own case queues; Jen is the only support team member who does not regularly interact with customers (she only engages when escalation warrants it)
- **Most cited reasons for enjoying the role:** variety of problems every day, no "Sunday scaries," strong team collaboration, the ability to ask any colleague for help on any product or issue, clear sense of purpose in helping clients
- **Company perks noted:** in-person company gatherings twice a year plus local regional meetups for geographically clustered employees – unusual for a fully remote company and cited as a meaningful benefit

Q&A with Support Team – Key Takeaways

- **Hardest part of the job:** managing demanding clients professionally even when pushback is repeated and the root cause clearly lies outside Evisions' product; maintaining the stance of "Switzerland" when a shared partner (eg Ellucian) is perceived by the client as underperforming – support cannot validate client complaints about partners as it would damage both relationships
- **Non-reproducible issues:** the most technically challenging cases are problems the client experiences consistently but Evisions cannot reproduce internally; without reproducibility, the scope of troubleshooting is severely limited and requires more information gathering, more client communication, and often escalation to engineering for a code-level review
- **Out-of-scope requests:** clients sometimes ask support to help with problems in systems or infrastructure that are adjacent to Evisions products but not within its scope; support wants to help but has to hold the line at what is actually in the support agreement
- **Handling frustrated customers:** constant communication is the most important tool – checking in regularly to let the client know work is ongoing prevents the vacuum of silence that turns frustration into escalation; Evisions' long-standing track record of delivery also builds tolerance – clients trust that a resolution will eventually come because it always has
- **Recurring issues:** product bugs that affect many clients simultaneously are identified through trends in the case queue; support creates JIRA bug reports and submits them to engineering; QA then builds regression tests to prevent recurrence; the feedback loop between support, engineering, and QA is how systemic issues get permanently resolved rather than repeatedly patched
- **Most-collaborated department:** engineering, because support is the primary conduit between clients and the engineering team for all bugs, defects, and enhancement requests; engineering rarely speaks directly to clients
- **Remote work and communication:** Slack has significantly improved cross-departmental communication compared to the pre-remote office era; intentional regular meetings (weekly, biweekly, quarterly) with other departments keep collaboration structured; support meets

regularly with sales, professional services, and client engagement

- **Support as a career launchpad:** analysts who learn Evisions products deeply become highly attractive candidates for QA, client engagement, product, and engineering roles; support is often described as the best place to learn how all the pieces fit together

Troubleshooting, Collaboration, and Escalations

Speakers: Kirsten (Support Manager), Jake and Christine (Support Analysts)

Best Practices in Troubleshooting

- **Know the product** – a support analyst must be an expert in what they support; clients call because they are lost and expect the analyst to know the product better than they do; analysts undergo extensive training before taking their first live case, with senior analysts reviewing their responses to ensure quality until they build independent experience
- **Read to understand, not just to respond** – analysts must read each case with the goal of genuinely understanding the problem, not just of finding something to say back; a case that says "I have a problem, help me" provides no basis for a solution without follow-up
- **Gather information and ask questions** – the quality of a troubleshooting path is determined by the quality of the information going in; insufficient detail leads to wasted time on the wrong problem; never make assumptions when a question can be asked instead
- **Key questions to ask when a problem is reported:**
 - Is this affecting one user or all users?
 - Is this happening with one report/feature or all reports/features?
 - What are the exact steps to reproduce the issue?
 - What version of the product (and OS, browser, driver, etc) are they on?
 - What is the exact error message shown, and where does it appear?
 - Is this happening in production or a test environment?
 - Has anything changed recently in their environment?
- **Web sessions for show-and-tell** – when text communication is insufficient, a Zoom screen share session allows the client to demonstrate exactly what they are experiencing; analysts can see the exact steps, the exact error, and the exact environment configuration in real time

Tracing and Narrowing Down

- **Form theories** – after gathering information, the analyst develops hypotheses about what could be causing the behavior; starting with multiple possibilities and testing to eliminate them is the core of structured troubleshooting
- **Tracing** – in code, tracing means following the execution path from input to output and inserting checkpoints to identify where behavior diverges from expectation; the same concept applies to product troubleshooting: follow the process step by step and identify the exact step where things go wrong
- **Isolate variables** – change one thing at a time; if the problem only occurs on one user's machine but not others, the variable is user-specific (account permissions, local configuration); if it only occurs with one record but not others, the variable is data-specific
- **Test, then test again** – a single successful reproduction does not confirm the root cause; repeat the test multiple times, then test with variations (different users, different data, different parameters) to confirm the issue is consistent and not coincidental; analogized to automotive testing – a car is not approved after one test drive on a smooth road
- **What to do when results are inconsistent** – if the same steps produce different results across repetitions, gather more information; inconsistency often means a contributing factor

has not yet been identified; go back to asking questions

Communication in Troubleshooting

- **Keep the client informed** – silence is the enemy of customer satisfaction; if a case is taking time, check in regularly to confirm work is ongoing even when there is no update to give; this prevents the customer from feeling forgotten
- **Involve the team** – remote collaboration tools (Slack, internal case notes, standup meetings) make it easy to solicit a second opinion; no analyst should struggle alone for days on a hard case; other team members may have seen the same issue previously or have a different angle to offer
- **Loop in the client engagement team** – when a case is long-running or a client's temperature seems to be rising, the client partner/engagement team can have a separate relationship-level conversation; this de-escalates without putting the analyst in an awkward position
- **Go on offense, not defense** – proactively reach out about aging cases rather than waiting for the client to escalate; proactive check-ins communicate that the analyst cares and is working on the problem; reactive responses after an escalation always feel worse to the client

AI in Troubleshooting – Comparison Exercise

- Breakout exercise: teams were given a minimal case description (a user unable to print a report; report opens correctly) and asked to troubleshoot it first without AI, then with AI
- **Without AI:** teams identified the likely split between printer-side and application-side causes, proposed gathering information on whether the issue was single-user or multi-user, suggested trying another printer and another report, and noted browser pop-up blockers as a potential factor in web-based printing
- **With AI:** AI provided the same categories of questions and tests but in a more structured, prioritized sequence (from simple checks like "is the printer online?" up to complex steps like resetting the print spooler and reaching out to a specialist); one team noted that AI "expanded on and made more specific" what the team had already identified; responses came significantly faster
- **Key observation:** AI outputs in troubleshooting are general starting points, not targeted solutions; without detailed context about the specific product, environment, and reproduction steps, AI cannot replace the analyst's product knowledge and judgment; the quality of AI output scales directly with the specificity and completeness of the prompt
- **Takeaway:** AI is a useful accelerator for structuring troubleshooting steps and generating questions to ask – but the analyst must still interpret the output, evaluate relevance to the specific scenario, and validate any proposed solution before applying it

Key Terms – Support Operations

- **KPI (Key Performance Indicator)** – a measurable value used to evaluate whether a team or process is meeting its goals
- **SLA (Service Level Agreement)** – a formal agreement defining what support will do, what response times are guaranteed by priority level, and what is outside scope
- **CSAT (Customer Satisfaction Score)** – survey-based measure of customer satisfaction with a support interaction; Evisions scores on a 1–5 scale
- **IPEDS (Integrated Postsecondary Education Data System)** – federal database where all higher ed institutions report enrollment data; used by Evisions to validate client-reported enrollment for pricing tier placement
- **Uptime SLA** – a commitment to minimum availability for cloud-hosted software, expressed as a percentage (eg 99.9%)

- **Perpetual License** – a one-time software purchase with optional annual support fees; client retains use of the software indefinitely
- **Subscription License** – recurring fee model (annual or multi-year) with support included; provides the vendor a predictable recurring revenue stream
- **Consumption Model** – pricing based on actual usage volume (eg AI tokens used, API calls made) rather than a flat fee
- **Tiered Pricing** – pricing that scales based on a usage or size metric (eg student enrollment) so larger or heavier users pay more
- **Tracing** – following the execution path of a process or code step-by-step to identify where behavior diverges from expectation
- **Deflection** – redirecting a customer to self-service resources (knowledge articles, web help) before they submit a case; reduces support volume and cost
- **Temperature** – informal term for the emotional state and frustration level of a client; monitoring temperature and acting before it boils over prevents surprise escalations
- **CET / Client Engagement Team** – the team that manages ongoing client relationships at a non-technical level; called in when technical support has stalled or a client’s internal frustration needs to be addressed at the relationship level

ewpage

7/1 – Support Presentations, Intro to DevOps & AWS, Cybersecurity & Tabletop

Support HW Presentations – East and West Teams

Presenter feedback from Jen, Director of Support

Measurements of Success

- **Support metrics (East)** – first response time / SLA met (eg 92% of tickets responded to within SLA); average resolution time (eg 8 business days); CSAT score from post-case survey; ticket volume categorized by issue type
- **Product metrics (East)** – data refresh success rate (measures whether dashboard data updates correctly upon ingestion – critical for an accelerator that is not a live feed and must be periodically refreshed); dashboard adoption / weekly active users (eg 75% of licensees are active users)
- **Support metrics (West)** – first-contact resolution rate (85% goal of cases closed in a single interaction); positive customer feedback trend per month; tickets completed within SLA timeframe
- **Product metrics (West)** – renewal rate (eg 90% subscription renewals); monthly active users per product
- **Jen’s feedback on measurements:**
 - Always define what the target is for each measurement – measuring without a target is just charting; the value is in triggering action when targets are missed
 - Measuring too many things produces 57 dashboards and noise; focus on KPIs that will actually drive decisions
 - Data refresh success rate was praised as a creative product-specific metric that Jen had not previously considered; highly relevant for an accelerator
 - Adoption is critical at product launch since there are no existing users to reference; early adopters become the testimonials that help acquire the next customer – in higher ed,

- word of mouth between institutions at conferences is a major sales driver
- 90% renewal rate was noted as slightly below Evisions’ own rate; churn (the inverse of renewal) is often the lens sales and customer success teams prefer – looking at loss rather than retention creates more urgency
- AI-generated dashboards (ChatGPT, PowerPoint AI) can produce far more visually polished output in a fraction of the time; the East team’s AI-built dashboard was complimented; Jen noted she is still creating her own the old-fashioned way for quarterly company reviews

SLA Design

- **East team SLA (four priority tiers):**

- Priority 1 (Critical) – system unavailable or students/advisors cannot access the platform; first response within 30 minutes, resolution within 4 hours; on-call coverage rather than advertised 24/7
- Priority 2 (High) – first response within 1 hour, resolution within 1 business day; Monday–Friday
- Priority 3 (Medium) – first response within 4 hours, resolution within 2 business days; Monday–Friday
- Priority 4 (Low) – first response within 1 business day, resolution within the academic week; Monday–Friday

- **West team SLA (four priority tiers):**

- Critical – dashboard inaccessible or scores not calculating institution-wide; response within 2 hours, 7 days/week
- Significant – core feature broken but platform accessible; response within 4 business hours
- Moderate – data displaying incorrectly or filters returning inconsistent results
- Informational – feature questions, non-urgent clarifications; response within several business days

- **West team additional SLA elements:**

- 99.7% monthly uptime guaranteed (vs. the industry standard 99.9%); rationale: the accelerator connects to multiple campus systems not under Evisions’ control, making 99.9% difficult to guarantee when sync failures may originate from institutions’ own systems; clients receive a 5% billing credit per full percentage point below threshold due to an Evisions-side failure
- Planned maintenance windows: weekends between 11 PM and 3 AM with 5 business days advance notice
- Evisions monitors all managed integration pipelines and notifies clients within 3 business hours of a detected sync failure
- Monthly integration health report provided to each client covering sync success rates, data latency, and incident failures
- Named support contact assigned to each account within 5 days of contract signing; West team acknowledged this creates a potential single point of failure and suggested a backup contact protocol
- Onboarding support included within the first 90 days post-implementation; extended weekend/after-hours coverage available for an additional 12% of annual license fees
- Version support: current release and one prior minor version; 60 days advance notice before a version moves to unsupported

- **Jen's feedback on SLAs:**

- Providing examples of what qualifies as each priority tier is critical – customers perceive everything as urgent; analysts must exercise judgment, and the SLA provides the reference point for those conversations
- 99.9% uptime is standard SLA language for hosted software; including a billing credit tied to missed uptime holds the company financially accountable and signals the commitment is serious
- 12% for extended coverage was praised as appropriately priced – on-call and after-hours staffing carries real operational costs (overtime pay or time-off compensation); it cannot be expected without additional compensation
- FERPA was highlighted as an important service commitment for higher ed specifically – student data privacy compliance must be explicitly called out in any higher ed product SLA
- The SLA naturally defines the support/professional services boundary; having it in writing prevents scope creep where support inadvertently does billable work for free
- Automatic case closure after 5 business days of no client response was flagged as something Evisions struggles with but wants to automate; cases waiting on client response clog queues indefinitely

Troubleshooting and Escalation Processes

- **East team (8-step framework):**

- Gather detailed information (institution, platform, browser, OS, user role, error messages, screenshots, timeline)
- Identify potential causes (data, integrations, compatibility, network, configuration, dashboard)
- Test basic troubleshooting (clear cache, try another browser/account/report, reproduce the issue)
- Apply a solution (reset configuration, refresh data, restore integration)
- Verify resolution with the client
- Log the case resolution for future reference and pattern detection
- Escalate if unresolved – with complete documentation (error messages, screenshots, steps taken) so the receiving tier does not duplicate work
- Escalation tiers: Tier 1 (support analyst – basic troubleshooting), Tier 2 (technical specialist – advanced troubleshooting), Tier 3 (professional services – if it requires paid development), Tier 4 (engineering – actual code/file-level investigation, then QA)

- **West team (4-step framework):**

- Intake and triage – confirm institution name, affected feature area, expected vs actual behavior; assign priority tier; log in support portal
- Analyst troubleshooting – verify integrations, filters, calculation logs, data feeds
- Escalation path: Senior support analyst (unknown problem) → Data engineering (pipeline failure or missing/stale data) → Software engineering (confirmed platform bug or regression) → Product (product gap or missing feature)
- Client communication and closure – never commit to a resolution timeline; close only after client confirms resolution or after 5 business days of no response

- **Jen's feedback on troubleshooting:**

- Questions are the foundation of effective troubleshooting; clarity on what actually happened prevents going down paths that do not exist

- Workarounds are an underrated tool – when a permanent fix requires engineering and may take weeks, a six-step workaround that gets the client what they need today is a meaningful partial solution
- Step seven (internal documentation) and resolution published in the customer portal are both critical; documentation enables self-service for future occurrences and ensures consistent answers across the team
- Never commit to a resolution timer is especially important; engineering cannot always give support a timeline, and engineering timelines frequently expand as root causes prove more complex than initially apparent

Pricing and Licensing

- **East team model:** annual SaaS subscription; tiered by enrollment – small institutions (under 2,500 students) at \$12,000/year; medium institutions (2,500–10,000 students) at \$30,000/year; large institutions (over 10,000 students) at custom pricing; optional add-ons include implementation (\$5,000 one-time), data migration (\$3,000), onsite training (\$6,000/year), premium support (\$4,500/year for 24/7 and a dedicated customer success manager); discounts for multi-year contracts (10%), nonprofits (5%), and statewide university systems (custom)
- **West team model:** annual SaaS subscription with tiered support levels; noted that ERP integration could add \$15,000–\$25,000 depending on the number of connected systems; pricing by school size noted as dependent on infrastructure cost per institution; paid virtual trainings available post-go-live once the product is stable enough to train on confidently
- **Jen’s feedback on pricing:**
 - Evisions’ current accelerator is priced at approximately \$10,000/year or higher; the East team’s model was in the right ballpark
 - Early-adopter programs (free for year one, then paid in years two and three of a three-year term) can be useful for new products that need reference customers, but clients without financial skin in the game tend to underinvest in adoption; requires active management
 - What is included vs what is an add-on must be explicitly communicated upfront; sales often sells to executives who do not pass the details to the end users, who then arrive at support unaware of what they paid for; welcome documentation sent at contract signing is important
 - More enrollment tiers are better; chunking from three tiers to five or six more accurately captures the range of institution sizes and reduces the likelihood of over- or under-pricing
 - Higher ed institutions are overwhelmingly nonprofit, so nonprofit discounts are common but should be structured carefully; private institutions typically have larger budgets
 - State university systems (eg Alabama College System with 27+ campuses) represent a distinct pricing challenge – they want bundle pricing across campuses, but the volume they bring warrants serious custom negotiation
 - **User adoption and PII note:** because accelerators are SaaS-hosted, Evisions can see usage data (who logged in, when); for on-premise products, this data would be invisible; SaaS hosting enables a much richer picture of adoption and product health

Intro to DevOps and AWS

Speaker: Will, Head of DevOps/IT/Security

DevOps – Definition and Evolution

- **DevOps** – a philosophy and set of practices that bridges the historically separate worlds of software development (writing code) and operations (running that code in production); the name is a portmanteau of Development + Operations
- The old model had developers write code, throw it over a metaphorical wall to operations, and leave operations to figure out how to deploy and maintain it; when things broke, each side blamed the other; the absence of shared context between the two groups created fragility and slow recovery
- DevOps emerged to create a continuous feedback loop: developers build in logging, alerting, and error recovery from the start; operations provides requirements to developers about what they need to run software reliably; the two sides are no longer adversaries
- The initial solution was a dedicated DevOps engineer role to bridge the two groups – but this person had no authority over either team and struggled to be effective; the industry has since moved toward DevOps as a culture rather than a job title
- Today, developers are expected to own the operational aspects of what they build: logging, alerting, error handling, and often initial on-call support; at companies like Amazon and Google, teams build and support their own services for months before handing off to an operations team
- At larger enterprises, dedicated **SREs (Site Reliability Engineers)** manage server infrastructure, deployment pipelines, and operational stability; this is the closer to the traditional operations model but running on cloud infrastructure
- Evisions no longer runs its own data center or physical servers; everything runs in the cloud (AWS); the era of racking hard drives and physically replacing failed components is over for most software companies of Evisions' size

AWS – Amazon Web Services

- **Origin of AWS:** Amazon built internal infrastructure tooling to handle massive scale on Amazon.com; they standardized how servers were provisioned, applications deployed, and errors monitored; at some point they recognized these tools had commercial value and could be offered as a service – AWS was born; Amazon runs on its own services internally, and different AWS teams actually charge each other market rates for usage to maintain honest P&L accounting
- **Core value proposition:** companies no longer need to buy, rack, power, cool, and maintain physical servers; they pay only for what they use, scaled up or down on demand; this eliminates massive upfront capital expenditure, enables faster time to market, and reduces ongoing maintenance burden
- **Cost model comparison:**
 - Owned server: high upfront cost (formerly \$50,000+ per server for Evisions); fixed cost whether the server is busy or idle; wasted capacity during low-traffic hours is pure cost with no return
 - AWS: pay-per-use; scale up during peak traffic, scale back down during off-hours; no idle cost; economics favor AWS for most businesses
 - Decision point: businesses must calculate whether their usage patterns justify owning vs renting; most companies today choose cloud because they want to focus on building their product, not managing infrastructure
- **AWS infrastructure structure:**
 - **Data center** – a physical building housing racks of servers; each rack contains many

individual server machines; AWS operates massive warehouse-scale data centers in locations chosen for cheap electricity and real estate

- **Availability Zone (AZ)** – a group of data centers within a metropolitan area, spread geographically so that a fire or disaster at one does not affect the others; provides redundancy and failover within a region
- **Region** – a geographic cluster of availability zones; examples in the US include US East (Virginia), US East 2 (Ohio), US West (California); regions also exist globally (London, Tokyo, Sydney, etc); companies choose regions based on latency (proximity to users), data residency regulations (eg European data must stay in the EU), and compliance requirements
- **Latency:** the milliseconds of delay between a user clicking something and a server responding; if a European user connects to a server in Los Angeles, every interaction adds the round-trip delay across the Atlantic; AWS regions close to users dramatically reduce perceived latency and improve user experience
- **Key AWS services:**
 - **EC2 (Elastic Compute Cloud)** – the foundational compute service; provisions a virtual server in seconds with a configurable operating system (Linux, Windows), CPU, memory, and storage; what previously took half a day to set up manually now takes roughly 20 seconds via the console; options range from a single vCPU/1 GB of RAM up to 64-core machines with 128+ GB of RAM for machine learning and compute-heavy workloads
 - **Storage** – scalable object and block storage services (S3, EBS) for files, backups, and database volumes
 - **Databases** – managed relational and NoSQL database services (RDS, DynamoDB) where AWS handles patching, backups, and scaling
 - **Machine learning** – managed AI/ML compute and pre-trained model services (SageMaker, Bedrock)
 - AWS offers hundreds of additional services spanning security, networking, IoT, quantum computing, satellite services, and more – all categorized in the AWS Console
- **AWS certifications:** vendor-recognized credentials that demonstrate foundational to advanced knowledge of AWS services; valuable for getting past resume scanners and getting in the door, but not a substitute for hands-on experience; most likely to get you noticed rather than to close the deal in an interview; security and AI certifications are currently more differentiated and closer to a career accelerant than general cloud certs; building a hands-on project portfolio is more compelling to most employers than certifications alone

Intro to Cybersecurity and Compliance

Speaker: Will, Head of DevOps/IT/Security

Cybersecurity Framework

- Will's three-category breakdown of cybersecurity:
 - **Traditional cybersecurity** – the tools, controls, and practices used to protect systems and data from bad actors; firewalls, MFA, endpoint detection, access controls, etc
 - **Compliance** – regulatory and industry standards that define rules organizations must follow; not directly protective but establishes guardrails and accountability (eg data must stay in the US, certain technologies are prohibited in government contexts)
 - **Privacy** – the rights and controls individuals and organizations have over personal

data; a philosophical and regulatory area that increasingly intersects with cybersecurity as data collection grows

- Attacks are increasing in frequency and sophistication, accelerated by AI; AI enables hackers to scale attacks that previously required significant manual effort – instead of targeting one large company for a single large payday, AI-assisted automation enables targeting thousands of smaller companies simultaneously for smaller but cumulatively larger returns

Ransomware

- **Ransomware** – malware that encrypts a victim's data or locks their systems and demands payment (typically in cryptocurrency) for the decryption key; the attacker may also steal data and threaten to publish it if payment is not received (**double extortion**)
- Modern ransomware groups (eg Hive) operate like businesses: they have professional websites where victims can log in with an attacker-provided key to verify exactly what data was stolen, a live support chat to help with payment questions, automated decryption key delivery upon payment, and a countdown timer to create urgency; the sophistication mirrors a legitimate e-commerce experience
- Ransomware is currently the dominant form of attack in the industry; it is used by both opportunistic criminals and state-sponsored groups

Phishing

- **Phishing** – a social engineering attack that tricks people into revealing credentials, clicking malicious links, or taking actions that give attackers access to systems; delivered via email, text (smishing), and increasingly via voice (vishing) or deep-fake impersonation
- Modern phishing is highly targeted (**spear phishing**): attackers aggregate data from public sources (LinkedIn, company websites, data leaked from prior breaches) to craft messages that reference real colleagues, real events, and real timing; examples: impersonating a CFO requesting gift card purchases, sending fake insurance enrollment links during the actual enrollment period, referencing a job the recipient actually applied for
- The old model of blasting one million random emails hoping for a 1% hit rate is being replaced by AI-assisted targeted approaches that dramatically increase hit rates
- Evisions has experienced phishing attempts during open enrollment periods and instances of employees purchasing gift cards believing the request came from leadership

Zero-Day Attacks and Living Off the Land

- **Zero-day attack** – exploiting a software vulnerability that is unknown to the vendor and has therefore not been patched; attackers have a window of opportunity between discovery and the release of a fix
- **Living off the land (LOTL)** – a modern attack technique that uses legitimate software already installed on a target's machine rather than deploying obvious malware; examples: using PowerShell (built into every Windows machine), screen-sharing tools like AnyDesk or TeamViewer (normal business software), and cloud storage like OneDrive or Google Drive to exfiltrate data; because these are approved tools, antivirus software does not flag them
- LOTL attack chain example: exploit a SharePoint vulnerability to gain RDP access → run PowerShell to install a screen-sharing tool → connect to internal network → spread laterally to personal devices on the same home network → encrypt data and upload it to the attacker's OneDrive account; nothing in this chain triggers antivirus
- **Cross-site scripting (XSS)** – injecting malicious scripts into a trusted website so that other users who visit the page execute the attacker's code in their browser; a common web application vulnerability

Compliance Standards

- **SOC 2 (System and Organization Controls 2)** – a widely used security and availability audit standard; auditors from accounting firms review over 100 controls (password complexity, MFA, access management, logging, incident response, etc) and issue a certification if controls are met; Evisions is SOC 2 certified; considered a baseline requirement for enterprise software vendors
- **ISO 27001** – international information security management standard; similar audit/certification process to SOC 2 but globally recognized; Evisions is ISO certified
- **HIPAA (Health Insurance Portability and Accountability Act)** – governs the handling of protected health information (PHI); relevant to healthcare software and any system processing medical records
- **PCI DSS (Payment Card Industry Data Security Standard)** – governs the handling of credit card data; required for any company that stores, processes, or transmits payment card information
- **GDPR (General Data Protection Regulation)** – European Union privacy regulation governing how companies collect, store, and process the personal data of EU residents; applies to any company serving EU customers regardless of where the company is located; violations carry significant financial penalties
- **CCPA (California Consumer Privacy Act)** – California state privacy law; one of the strictest in the US; requires websites to display a cookie consent banner and give users the ability to opt out of data tracking; failure to display the banner can result in fines of up to \$10,000 per user who visited the site; has created a cottage industry of attorneys who identify non-compliant websites and file suits
- **FERPA (Family Educational Rights and Privacy Act)** – governs access to student educational records at institutions receiving federal funding; relevant to all Evisions higher ed clients; students must sign a waiver for parents to access their records; any system handling student data must account for FERPA compliance

Tabletop Exercise – Ransomware Attack Scenario

- **What a tabletop exercise is** – a structured scenario discussion where a team works through how they would respond to a simulated security incident; not a technical drill but a conversation about decision-making, roles, communication, and priorities; used by security and compliance teams to identify gaps in incident response plans before a real event occurs
- **Scenario presented:**
 - Tuesday morning: help desk receives calls – employees cannot access files; ransom notes appear on desktops demanding cryptocurrency; attackers claim to have encrypted servers and stolen customer data with a threat to publish it; email services go down; employees begin posting about the incident on social media; local news outlets start calling; major customers start calling
 - Phase 2: the customer portal goes offline entirely; revenue impact reaches \$100,000/day; attackers demand \$2 million in crypto within 48 hours; backup restoration is estimated at 10 days
- **Key response steps and discussion points:**
 - **Contain social media** – immediately address employees posting about the incident; uncontrolled public information worsens the reputation impact and may complicate legal obligations
 - **Verify the breach before panicking** – confirm the attackers actually have what

they claim; log files, network access audit trails, and anomalous traffic from unexpected geographies are initial indicators; organizations sometimes pay ransoms for data the attacker never actually had

- **Isolate affected servers** – disconnect systems from the network to stop lateral spread and additional encryption; identify which specific servers the attackers referenced
- **Notify executives – with awareness of their communication preference** – some executives want to know immediately even if no solution exists yet; others want to be briefed only when there is a proposed course of action; this preference should be established before an incident, not during one
- **Do not notify customers yet** – without a clear picture of what happened, early customer notification risks miscommunication and additional panic; however, disabling application access may be warranted to stop additional data exposure
- **Legal, insurance, and law enforcement notifications:**
 - * Cyber insurance must typically be notified within 24 hours of a known or suspected incident; failure to report can void the claim
 - * Legal counsel must review contracts to identify per-customer notification obligations and timelines (eg "notify within 24 hours" vs "within 72 hours")
 - * Law enforcement (FBI) notification may be legally required, particularly when the affected data involves institutions receiving federal funding; the FBI has a dedicated hotline for cyber incident reports
- **Pay vs restore decision (Phase 2):**
 - * Financial analysis: at \$100,000/day revenue loss and a 10-day restoration timeline, the restoration path costs \$1 million before any recovery costs; the ransom demand is \$2 million; pure math may favor paying, but the decision involves far more than math
 - * **Reputation with attackers** – paying signals that Evisions will pay, making it a future target; analogous to why governments don't negotiate with terrorists – paying creates an incentive for repeat attacks
 - * **Customer loyalty** – extended downtime (10 days) risks customers moving to competitors who are still operational
 - * **Downstream impact** – customers who depend on Evisions to run their own operations are also losing money; this multiplies the urgency of communication
 - * **Transparency vs spin** – companies choose between full public disclosure (builds trust, allows customers to protect themselves, demonstrates accountability) and quiet resolution (protects short-term reputation but risks severe backlash if the truth emerges later); publishing a detailed blog post about what happened and what is being done is increasingly the preferred approach among reputable companies
 - * **Engage negotiators** – ransomware negotiators (often former law enforcement or FBI) can open dialogue with attackers, gather intelligence about their identity and motivation, buy time, and potentially reduce the ransom amount; this is a recognized profession with practitioners embedded in cyber insurance response teams
 - * **Forensic investigation** – security forensics experts analyze logs, network traffic, and file system changes to reconstruct the attack chain, identify the entry point, and potentially attribute the attack to a known group; this information supports law enforcement investigation and insurance claims
- **Qilin ransomware group** – mentioned as an example of a sophisticated China-affiliated ransomware operation; illustrates that modern ransomware is often state-sponsored or pro-

professionally organized at a nation-state level, not merely individual opportunists

CISO Career Note

- **CISO (Chief Information Security Officer)** – the executive responsible for an organization’s information security program; one of the highest-paying and most in-demand roles in technology; salaries commonly in the \$300,000–\$500,000+ range for large organizations
- The CISO role carries extreme accountability: when a breach occurs, the CISO is typically the first executive to be held responsible, regardless of whether the failure was within their control; industry pattern described as ”CISOs come in threes” – the first is fired after the breach, the second burns out from the remediation workload, and the third finally achieves stability
- The cybersecurity industry has a significant talent shortage; there are more open roles than qualified candidates, creating strong compensation and career stability for those who pursue it

ewpage

7/2 – AI Security & Compliance

Speaker: Will, Head of DevOps/IT/Security

AI Evolution and Architecture

Generative AI – From Chatbots to Agents

- **Basic chatbots (pre-2022)** – rule-based or keyword-driven systems that scraped publicly available information to respond to queries; no real reasoning, just pattern matching and information retrieval; outputs were often hallucinated because the system simply found a keyword match and returned it without verification
- **RAG (Retrieval-Augmented Generation)** – the next evolution; chat interfaces augmented with an organization’s own documents, PDFs, spreadsheets, and data stores; the model can now reference internal material to answer questions rather than relying solely on public training data; enables business-specific use cases like ”search our policy documents”
- **Agents** – a significant shift; agents do not just respond, they plan; given a goal, an agent thinks through the best approach, determines what tools or data sources are needed, reaches out to external APIs, formats the output appropriately, and may include images or pull from multiple sources; the user sees a response while all this orchestration happens invisibly
- **Agent-to-agent** – agents coordinating with each other; one agent may delegate subtasks to specialized agents (”you’re good at scanning documents, you handle that part”) and synthesize the results; analogous to a project manager coordinating a team
- **Multi-agent systems** – a lead orchestrator agent plans and delegates work across a network of specialized sub-agents, each interacting with specific tools and APIs; the user interface remains simple while enormous complexity runs in the background; in a large enterprise with 10,000 users and many AI tools, this architecture can generate hundreds of millions of agent-to-tool calls per day
- **MCP (Model Context Protocol)** – a protocol that enables agents to interact with external tools and services in a standardized way; allows agents to plug into calendars, email, Salesforce, source code, and other internal systems to retrieve and act on data
- AI adoption has gone from near-zero in 2022 to exponential corporate investment; companies that once cautioned ”AI won’t replace jobs” followed months later with significant layoffs driven by AI-enabled efficiency; the technology is moving faster than most organizations’

governance frameworks can keep up with

AI vs Humans vs Traditional Machines

- **Humans** – strong judgment, emotional intelligence, common sense, contextual understanding; limited by speed and scale (one person, one task at a time)
- **Traditional machines/software** – extremely fast and scalable; rigid rule-based; cannot make assumptions or handle ambiguity; requires explicit, exact instructions
- **AI agents** – fast and scalable like machines, with broader scope than single-purpose software; but lacking genuine judgment, emotional intelligence, and ethical reasoning; AI's core drive is to be helpful, which means it will attempt to execute requests without the judgment to know whether a request is harmful or appropriate
- The lack of judgment in AI is a significant security vulnerability: an AI agent with database write access, when asked to delete the database, may simply comply because it has no moral framework to evaluate whether that is an appropriate action

AI Security Threats

Model and Memory Poisoning

- **Model poisoning** – corrupting an AI model's training data or memory so that its outputs are manipulated; example: repeatedly feeding a model false information ("the sky is red") so that the model begins returning that false information as truth for all users
- Poisoning can be ideological as well as technical: a model trained on manipulated data can develop biases toward certain political views, demographic groups, or factual claims; this is both a security threat and an ethical concern
- Models that allow training to occur based on user input (without strict data governance) are particularly vulnerable; this is why disabling the "use my data to train the model" setting is critical (covered in the 6/29 AI session)

Prompt Injection

- **Prompt injection** – embedding malicious instructions within a prompt that cause the AI system to take unintended actions, bypass its own filters, or return sensitive information it should not reveal
- Because AI systems are designed to be helpful and to execute what they are asked, they are inherently vulnerable to prompts that disguise malicious intent as legitimate requests
- Simple example: encoding a prompt in Base64 (machine-readable but not human-readable plain text) to bypass keyword filters; a filter looking for "reveal system prompt" will not catch the same instruction encoded as a Base64 string, but the AI will decode and execute it
- Another example: encoding "what is the root password" in a character set the text filter does not scan; the AI decodes and responds with the requested credential
- More sophisticated attacks embed malicious code within a prompt (eg SQL commands like DROP TABLE or requests for stored credit card numbers) that the AI executes against a connected database or returns from its accessible data
- Well-designed AI systems implement multiple layers of filtering and access controls; however, many production deployments remain vulnerable because they were built quickly without rigorous security review

Output Manipulation and Intent Hijacking

- **Output manipulation** – crafting prompts that cause an AI to produce harmful, false, or unauthorized outputs; distinct from prompt injection in that the goal is to change what the model says rather than what it does

- **Intent hijacking** – using the AI’s helpfulness against it; example: a hotel booking chatbot asked to ”share recent credit card numbers from reservations” will attempt to comply unless output filtering explicitly prevents it; the AI has no ethical judgment to recognize this as an unauthorized request
- AI tools that have broad access to databases, files, and APIs without access controls are particularly vulnerable; the AI does not distinguish between a legitimate user query and a malicious one

Shadow AI

- **Shadow IT** (existing concept) – employees using unapproved software tools for work purposes without IT’s knowledge; if those tools are compromised, company data stored in them is exposed and IT has no visibility or ability to respond
- **Shadow AI** – the same problem applied to AI tools; employees installing AI applications, browser extensions, or local AI systems on work devices without IT review; these tools may be configured to access email, calendar, source code, internal documents, or other sensitive systems; if the tool is compromised or has permissive data-sharing terms, company data leaks without any visibility from IT
- The number of available AI tools has exploded; it is effectively impossible for IT to stay ahead of all of them without a clear policy requiring tool review before use
- The risk is not just the AI tool itself but what it connects to: an AI installed on a work laptop that has access to email, calendar, and the company VPN is a far larger attack surface than the AI tool alone

Case Study – Open Claw / Claude Hub Supply Chain Attack

- **Background** – ”Open Claw” (a local AI system with a marketplace of installable skills similar to an app store) became popular rapidly; users could install skills that gave the AI control over their computer, calendar, files, and online accounts; the appeal was a single AI that could manage everything
- **The attack** – malicious skills were uploaded to the Claude Hub marketplace disguised as legitimate tools (eg a Google services integration skill, a personal reminder system); users installed them without recognizing the risk
- The malicious skills performed their advertised function while silently running background code to siphon data: capturing keystrokes, stealing email content, monitoring banking sessions, and uploading sensitive data to attacker-controlled cloud storage
- Because the AI had been granted access to essentially the entire computer, the blast radius of a compromised skill was massive – not just the data the skill was supposed to touch, but everything the agent could reach
- Many companies banned Open Claw from work devices entirely after discovering employees had installed it on company machines; some employees lost personal data as well
- **Key lesson** – any AI tool given broad system access is a potential supply chain attack vector; the more access an AI agent has, the higher the stakes if a skill, plugin, or integration is malicious

AI Governance at Evisions

Tool Review and Approval Process

- Every AI tool, model, or integration used at Evisions must go through a security review conducted by Will’s team, supplemented by outside security consultants
- Review covers: data handling and security controls, terms of service (specifically whether the

vendor claims rights to use customer data for model training), compliance with relevant data privacy regulations, and technical integration security

- Terms of service are a critical and frequently overlooked risk factor; many AI services include buried clauses asserting the right to use submitted data for model training; users rarely read these terms but are legally bound by them
- Notable examples of undisclosed data use: Meta/Instagram/WhatsApp reading encrypted messages for model training data (exposed by a whistleblower); Amazon's AI hiring tool being biased due to training data issues; Clearview AI scraping public images without consent to build a facial recognition database
- Even tools that Evisions has already approved must go through a new review if they add an integration with another tool – the combined data flow creates new attack surfaces not covered by the original approval

AI Data Classification Exercise – What Is Safe to Input?

- Will walk through a series of data types to evaluate the risk of inputting them into a public AI model that may train on submitted data; key takeaways below:
 - **A general coding question** – low risk; no company-specific or sensitive data is provided; the query is the kind of thing already publicly available; acceptable
 - **A code snippet with no proprietary logic** – low risk if the snippet is generic and reveals nothing about authentication schemes, proprietary algorithms, or internal architecture
 - **Employee handbook** – moderate risk; if it contains unique company policies, it could expose internal practices or create legal exposure; technical architecture diagrams at a high level are generally acceptable since many are already public; detailed internal architecture is not
 - **Product roadmap** – higher risk; even if some roadmaps are published publicly for transparency, internal roadmaps are often competitive intelligence; a competitor who knew Evisions' 12-month roadmap could accelerate their own development to beat Evisions to market on key features
 - **Authentication code** – do not input; reveals the logic of how users are authenticated, which can be analyzed by hackers or AI tools to find exploitable vulnerabilities
 - **Web traffic logs with student data** – do not input; logs frequently contain IP addresses, session data, student IDs, and other PII; once submitted to a public model, the data is potentially accessible via prompt queries by any user
 - **Support log files containing student records** – do not input; same PII concerns; student data is protected under FERPA and carries significant legal liability if exposed; a customer could sue Evisions for submitting their student data to a public AI model
 - **Zoom/meeting recordings from engineering sessions** – do not input; recordings may contain screen-shared source code, sensitive discussions about pricing, unreleased features, or personal information; the content of any recorded meeting is unpredictable and potentially sensitive
- **General framework for evaluating AI input risk:**
 - What is the worst-case impact if this data were exposed publicly or used to train a model accessible to others?
 - Does it contain PII, financial data, credentials, or proprietary business logic?
 - Could exposure of this data result in legal liability, reputational harm, or competitive disadvantage?

- Higher-impact data (student records, financial records, passwords, authentication code) is high risk; lower-impact data (general coding questions, publicly documented architecture) is lower risk
- The decision is not always binary – there is often a safe subset of information that can be shared while the sensitive details are redacted or excluded

AI Ethics

Algorithmic Bias

- AI models trained on biased data produce biased outputs; this is not hypothetical – Amazon’s AI hiring tool was found to systematically disadvantage certain genders and ethnicities because the training data reflected historical hiring patterns that were themselves biased; the model learned and amplified the bias rather than correcting it
- Bias can enter through: skewed training data, biased labeling choices, lack of diverse representation in the teams designing the system, and reinforcement of historical patterns that are already discriminatory
- Using AI for high-stakes decisions (hiring, lending, criminal justice, medical diagnosis) without rigorous bias testing creates real harm for real people

Facial Recognition and Privacy

- Clearview AI built a facial recognition database by scraping publicly posted images from the internet (social media, news sites, public profiles) without individual consent; their legal argument is that publicly posted images are public information
- Law enforcement agencies have licensed Clearview technology, enabling real-time identification of individuals in public spaces; someone who posted a photo on Instagram years ago may now be identifiable on the street without ever consenting to facial recognition use
- The ethical debate: does publishing a photo online constitute permanent consent to any future use of that image, including identification and tracking? The regulatory answer varies by jurisdiction; the ethical consensus is far less settled

Autonomous Vehicle Ethics

- Tesla and other autonomous vehicle developers must encode ethical decision-making into their AI – decisions that philosophers have debated for centuries must be reduced to code
- Example scenario: an unavoidable collision is imminent; the AI can either stay course (hitting a wall, likely killing the driver) or swerve (hitting pedestrians, killing others); whichever choice the AI makes, it is making a life-and-death ethical decision autonomously
- Tesla is actively training its AI to make these decisions by calculating survival probabilities and optimizing against defined objectives; the question of whose life the AI should prioritize (driver, pedestrians, number of people, identity of individuals) has no universally agreed answer and has significant legal implications
- This class of problem highlights that AI ethics is not a theoretical concern – it is embedded in production systems making real decisions today

AI-Generated Misinformation

- AI enables the creation of highly convincing synthetic media: deepfake videos and audio, fabricated quotes attributed to real people, and fake news articles indistinguishable from legitimate reporting
- During elections, AI can be used to target specific demographic groups with tailored misinformation at scale; the speed and personalization possible with AI far exceed what human-operated influence campaigns could achieve

- Verification of digital content is increasingly difficult; even sophisticated users struggle to identify deepfakes or AI-generated text; the practical effect is that trust in all digital media is eroding

Phishing Simulation Assignment

- Evisions runs ongoing phishing simulations against its own employees – sending fake phishing emails on a regular cadence to test whether employees click links, download attachments, or scan malicious QR codes; results are tracked to identify patterns and inform security awareness training
- Interns were assigned to create their own phishing email templates, which Will’s team will incorporate into future simulations; interns will also receive phishing simulation emails from Evisions and may receive their own created template
- **Template requirements:** sender email address (can be a convincing fake, eg a misspelling of a legitimate domain), sender display name, subject line, email body (plain text or HTML; can include images, QR codes, or links), and a difficulty rating (1–5, where 5 is the most convincing/difficult to detect)
- **Indicators used by analysts to assess phishing emails:**
 - Sender domain – does it match the legitimate domain of the claimed sender? A non-Microsoft domain claiming to be Microsoft is an immediate red flag; close misspellings (eg "Micros0ft") are more dangerous
 - **DMARC / DKIM verification** – email authentication standards; the receiving mail server queries an independent authority to confirm whether the claimed sending domain authorizes emails from the originating IP address; if DMARC/DKIM fail or cannot be verified, the email is flagged as suspicious; legitimate large senders (Google, Microsoft) always pass these checks
 - Email headers – contain metadata about the email’s routing, authentication results, and originating server; analysts review headers to confirm or rule out phishing when reported
 - Urgency or unusual requests – creating time pressure or requesting unusual actions (gift cards, credential entry, insurance form completion during a known enrollment period) are common manipulation tactics
 - Mismatched links – hovering over a link reveals the actual URL, which in phishing emails typically differs from the displayed text or logo
- Evisions employees can report suspicious emails via a Fish Alert button in Outlook, which deletes the email from the inbox, reports it to Microsoft, and sends it to Will’s team for analysis; confirmed phishing domains are then blocked so repeat attempts to the same organization are prevented
- **Shadow AI note from the assignment context** – employees should not use personal AI tools on work devices to create work deliverables; any AI tool used for work tasks should be IT-approved to prevent data from flowing to unapproved and potentially insecure systems

Key Terms – AI Security and Compliance

- **RAG (Retrieval-Augmented Generation)** – an AI architecture that augments a language model’s responses by pulling from a specific document store or database rather than relying solely on pre-trained knowledge; enables AI to reference internal business documents
- **AI Agent** – an AI system that not only generates responses but plans, selects tools, calls external APIs, and takes actions to accomplish a goal; has a broader scope and more autonomy than a basic chatbot
- **MCP (Model Context Protocol)** – a protocol enabling AI agents to interact with external

tools and services in a standardized way

- **Multi-Agent System** – an architecture where a lead orchestrator agent plans and delegates subtasks to specialized sub-agents, each optimized for specific functions
- **Model Poisoning** – corrupting an AI model’s training data or memory to manipulate its outputs; can introduce false information or bias
- **Prompt Injection** – embedding malicious instructions in a prompt to cause an AI system to bypass its filters, take unauthorized actions, or reveal restricted information
- **Shadow AI** – the use of unapproved AI tools on work devices or with work data without IT’s knowledge; creates security vulnerabilities and data exposure risks analogous to shadow IT
- **Supply Chain Attack** – an attack that compromises a software product or component earlier in its development or distribution chain; in the AI context, malicious skills or plugins uploaded to an AI marketplace that appear legitimate but contain hidden malicious code
- **Living Off the Land (LOTL)** – using legitimate, pre-installed software tools as attack vectors so antivirus systems do not flag the activity (covered in cybersecurity session on 7/1; referenced here in the context of AI-assisted attacks)
- **DMARC / DKIM** – email authentication protocols; DMARC (Domain-based Message Authentication, Reporting and Conformance) and DKIM (DomainKeys Identified Mail) verify that an email claiming to come from a domain was actually authorized by that domain; used by analysts to identify spoofed sender addresses
- **Algorithmic Bias** – systematic and unfair discrimination in AI outputs caused by biased training data, biased labeling, or underrepresentation in model design
- **Deepfake** – AI-generated synthetic media (video, audio, images) that realistically depicts real people saying or doing things they never did; increasingly difficult to distinguish from authentic content
- **Phishing Simulation** – a controlled internal security test where an organization sends realistic fake phishing emails to its own employees to assess click-through rates and identify employees who need additional security awareness training
- **Fish Alert** – Evisions’ internal Outlook button for reporting suspected phishing emails; triggers automatic inbox deletion, reports to Microsoft, and flags the sender domain for IT review and potential blocking